

JSON Web Encryption (JWE) in Depth



Scott Brady

Identity Consultant & Engineering Manager

@scottbrady91

www.scottbrady91.com



Overview



What is symmetric and asymmetric encryption?

How to recognise and use encrypted JWTs

When to use JSON Web Encryption (JWE)

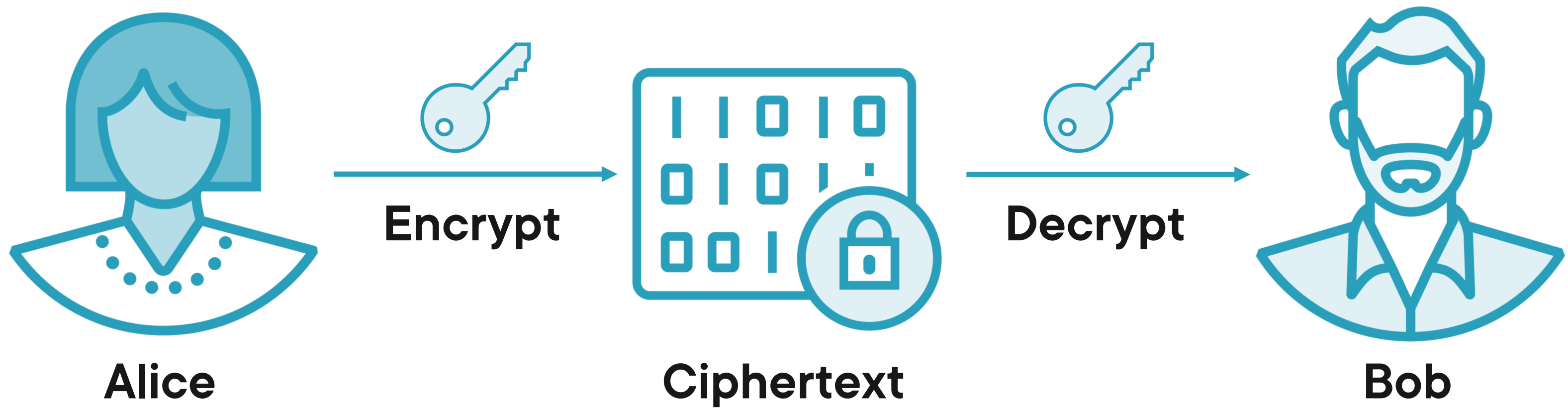
How to choose the right encryption algorithm



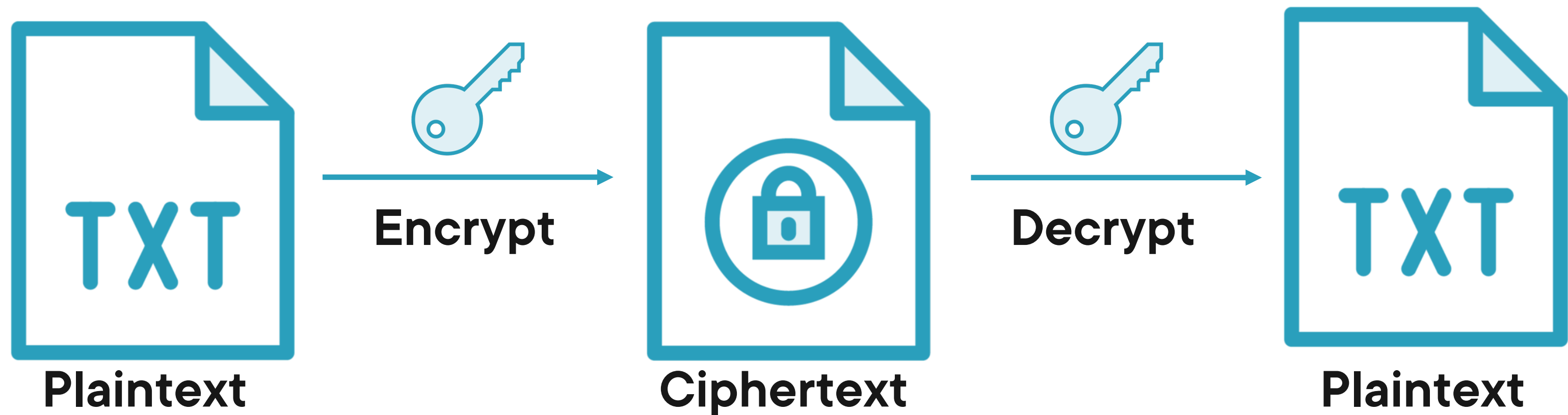
Understanding Encryption



Encryption



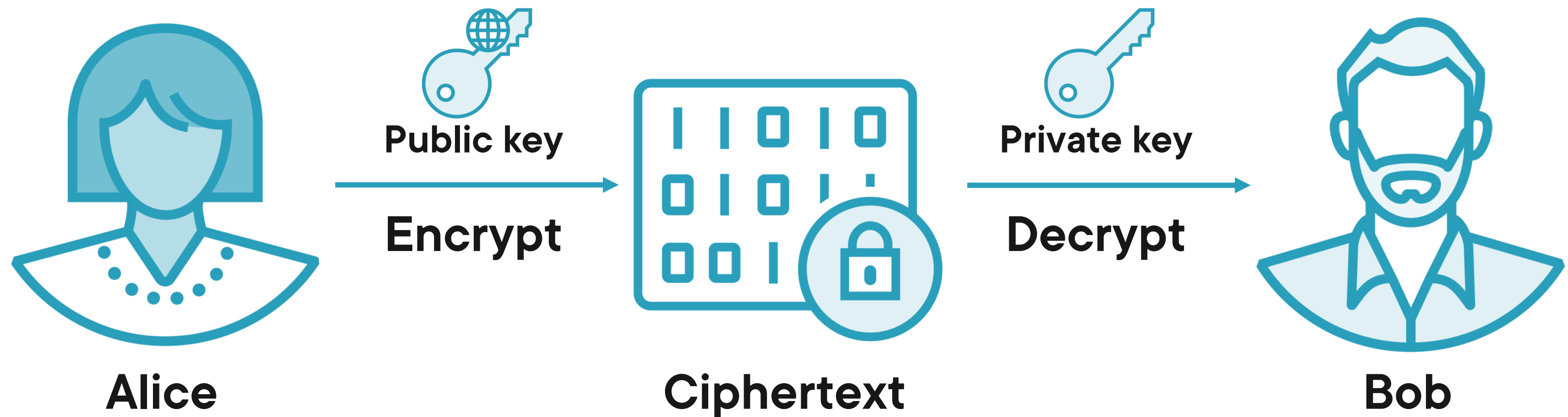
Symmetric Encryption



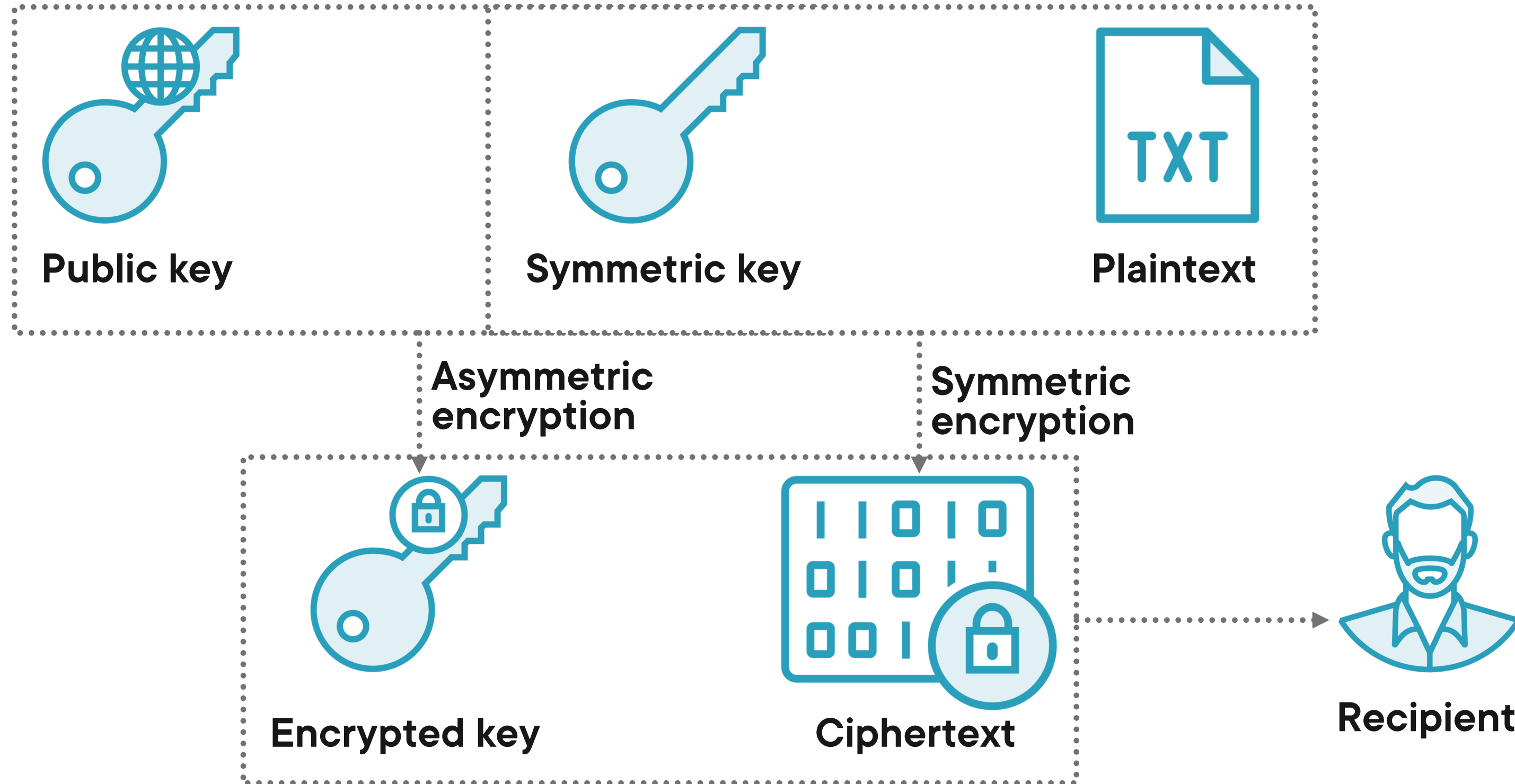
Asymmetric Signing



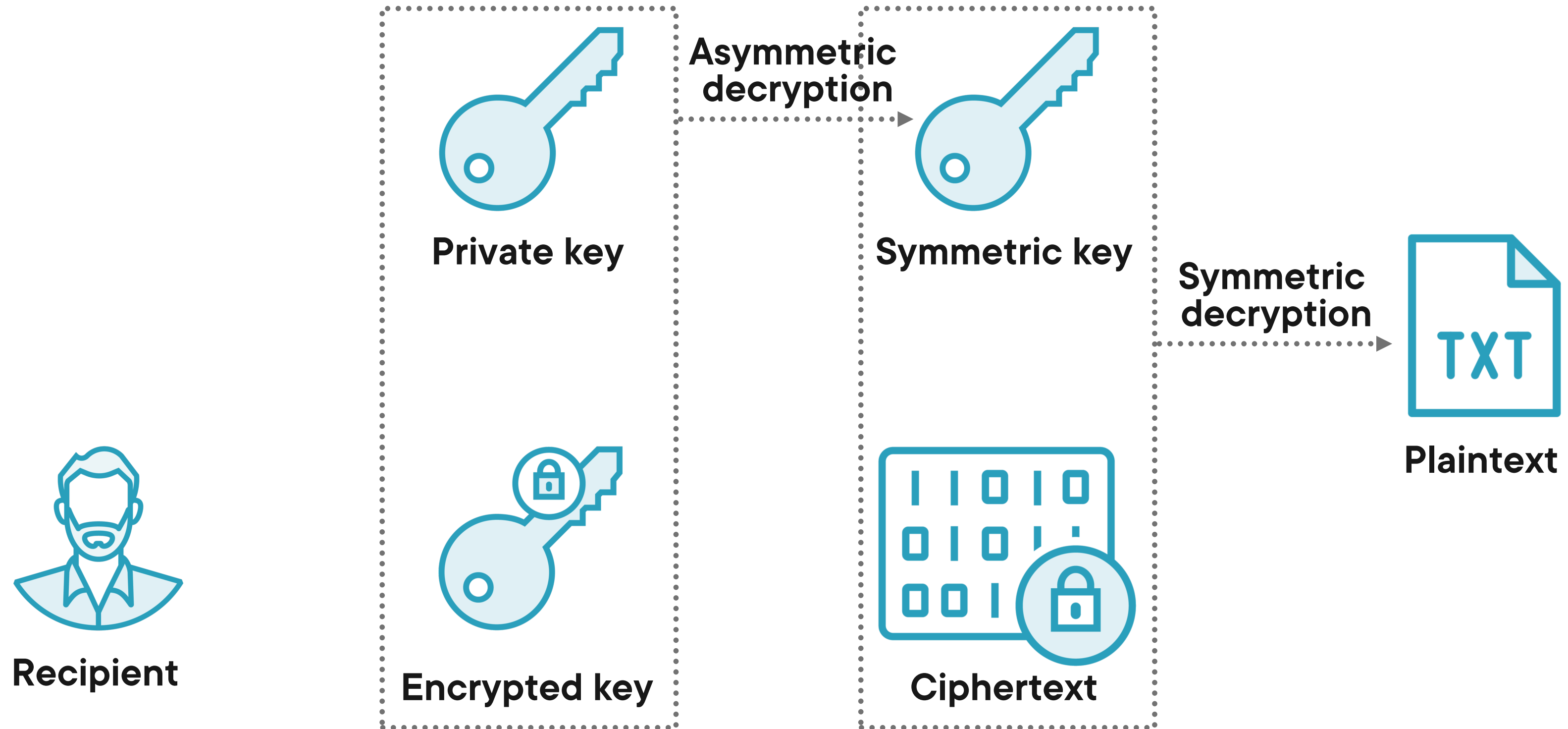
Asymmetric Encryption



Hybrid Encryption



Hybrid Encryption



Hybrid Encryption



Slow asymmetric encryption only used on small key



Fast symmetric encryption used for large message



Fresh symmetric key generated per message



Encryption Algorithms

RSA

AES



JWT Encryption with JWE



JWE Structure

eyJhbGciOiJSU0EtT0FFUCIsImVuYyI6IkpEYNTZDQkMtSFM1MTIiLCJraWQiOiI1MDNiYTkyMDQxZjE0YTRkYjVmOGI5ZDc4NmM3OTQwZSI6ImN0eSI6IkpXVCJ9.pTHHed-IGYf_7mleQEY010h7gb10HMEBcjz254HJTyX3h5SCINxJ546mlabX05zhxDFXDlPnDkz4qzuR9671ioD8Y2bAwj2zdHNuzcheQK1LgitcXfeUCPRRUaCdm6me_oBTX7a6eJTn_QaVhBpYXDHJ35CJ0nMZmQLz3GrkitrI2UTn59I0-X0gRNscByEtWZlbXBZhYljaaxxmJ2cexN79YYc1df3zg81uJn0XgPVwWjys6n2bAWi_g7L8GRbrIKN3L77q9KGLM_6y-Phv-eyshi3C5z6zD7MspZ12XS_GTEHfF1FIPkk_jwdJVylrJ864v1nTxQ6TI16H4gS2kg.Bfb0EauIdjxAYBNYMA5MCA.zmXKL2zMCalxPK4CinQu4GQBBAvfKp-XlPS0WpMvCQhJ0WePRiWXsNxzpyoe8GiAg8j8Je8oxkV7P_ETlr7pmn1uu90p9bX3Lm7ThmULKB3pr6nt8Zm7wIpIV4SPs9D7b8rhF0WKg7_lubrNtFM2Aci b0sejZa2QFkU5jYBCq2Zl9zBZ90njIXcxqUrT_lvVi7ULIfdVALcRwHtFB3vArEv2jB42bXYAd7kfQyfAjWSVJr6jG0YuB IKIT5PnWlx0ZZWvxph0HpWEQiW8TpjrYbDwycsDM2dbi-4_kZsMyA0zz7oIxQqaNB_M07HR2hHQfo_73WToGh5Gu79HEus ZmTCycoNJDWnsSushuTVdIBafGSoTaYqRyxhnIbF2GHjLguMGSDpvt0HmMKXborizoYQSdH5MpprL8pkAvYIJNRwkU353b JlhPo5foQZOG-pnAVT036QU2cEkE3s-sU5jRJVLsmN2v2APo2fbyyy11H80Gj43c4El0xQoS37QKpwL7m1xJR3QJ_9tiFZ JzYPmd0A2025U7v2HPykyLuvCoakNrh1FYr5vTLjZK11GUih3DQDGBGQfhQu00A186bMBsR9rNnAPL4V0oybdqZpAQDTFs X-fh2p7jF8xP50DRN4NqwSPFLjGDAX1g_nFPuYpWJKkFgYTsJyzkerZGSB17nVCkVbb0swR00cbFo_gZumb37e7YsLijDw 1bfPmGQqw37DA_oKqSHP3aqDIaxfSQM.12Y11L2b45S9GY7aak015IVKZW-_J-mL1BoHS1IFpX0




```
{  
  "alg": "RSA-OAEP",  
  "enc": "A256CBC-HS512",  
  "kid": "503ba92041f14a4db5f8b9d78737940e",  
  "typ": "JWT",  
  "cty": "JWT"  
}
```

JWE Protected Header

Describes the JWE token, how it was encrypted, and what content it is protecting.

Protected by authenticated encryption.

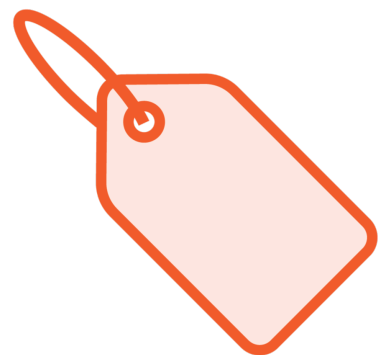
Authenticated Encryption



Confidentiality, integrity, and authenticity



Can protect additional data



Produces authentication tag



pTHHed-

IGYf_7m1eQEy010h7gb10HMEBcjz254HJTyX3h5SCINxJ546m1abX05zhxDFXD1PnDkz4qzuR9671ioD8Y2bAwj
2zdHNuzcheQK1LgitcXfeUCPRRUaCdm6me_oBTX7a6eJTn_QaVhBpYXDHJ35CJ0nMZmQLz3GrkitrI2UTn59I0-
X0gRNscByEtWZ1bXBZhY1jaaxxmJ2cexN79YYc1df3zg81uJn0XgPVwWjys6n2bAWi_g7L8GRbrIKN3L77q9KGL
M_6y-Phv-eyshi3C5z6zD7MspZ12XS_GTEHfF1FIPkk_jwdJVy1rJ864v1nTxQ6TI16H4gS2kg

Content Encryption Key (CEK)

Symmetric encryption key that has been encrypted using asymmetric cryptography (e.g. RSA-OAEP).

Bfb0EauIdjxAYBNYMA5MCA

Initialization Vector (IV)

Used during symmetric encryption.

Must be unique per token.

If encryption algorithm does not require IV, then must be empty.

zmXKL2zMCa1xPK4CinQu4GQBBAvfkP-
X1PS0WpMvCQhJ0WePRiWXsNxzpyoe8GiAg8j8Je8oxkV7P_ET1r7pmn1uu90p9bX3Lm7ThmULKB3pr6nt8Zm7wI
pIV4SPs9D7b8rhF0WKg7_lubrNtFM2Acib0sejZa2QFkU5jYBCq2Z19zBZ90njIXcxqUrT_1vVi7ULIfdVALcRw
HtFB3vArEv2jB42bXYAd7kfQyfAjWSVJr6jG0YuBIKIT5PnW1x0ZZWvxph0HpwEQiW8TpjrYbDwycsDM2dbi-
4_kZsMyA0zz7oIxQqaNB_M07HR2hHQfo_73WToGh5Gu79HE-
usZmTCycoNJDWnsSushuTVdIBafGSoTaYqRyxhnIbF2GHjLguMGSDpvt0HmMKXborizoYQSdH5MpprL8pkAvYIJ
NRwkU353bJ1hPo5foQZ0G-pnAVT036QU2cEkE3s-
sU5jRJVLsmN2v2APo2fbyyy11H80Gj43c4E1oxQoS37QKpwL7m1xJR3QJ_9tiFZJzYPmd0A2025U7v2HPykyLuv
CoakNrhlFYr5vTLjZK11GUih3DQDGbGQfhQu00A186bMBsR9rNnAPL4V0oybdqZpAQDTFsX-
fh2p7jF8xP50DRN4NqwSPFLjGDAX1g_nFPuYpWJKkFgYTsJyzkerZGSB17nVCkVbb0swR00cbFo_gZumb37e7Ys
LijDw1bfPmGQqw37DA_oKqSHP3aqDIaxfSQM

Ciphertext

The encrypted message that has been encrypted using symmetric cryptography. Requires the use of authenticated encryption (e.g. A256CBC-HS512).

Created using the message, IV, CEK, and protected header.

12Y11L2b45S9GY7aak015IVKZW-_J-mL1BoHS1IFpX0

Authentication Tag

Used to ensure the integrity of the ciphertext.

If encryption algorithm does not require tag, then must be empty.

JWE Message



Can be anything



JWE: confidentiality, integrity, and authenticity



JWS: integrity, authenticity, and non-repudiation



```
{
  "alg": "RS256",
  "kid": "503ba92041f14a4db5f8b9d78737940e",
  "typ": "JWT"
}

{
  "sub": "5be86359073c434bad2da3932222dabe",
  "aud": "api1",
  "iss": "idp",
  "exp": 1657193453,
  "iat": 1657189853,
  "nbf": 1657189853
}
```

Nested JWT

A signed JWT (JWS) which must itself be validated.

Allows you to prove who created the token.

When to Use JWE



Personally Identifiable Information (PII)

Names

Email address

Street address

IP address

Account number

Telephone number



Identity Tokens Containing PII

```
{  
  "iss": "https://idp.local",  
  "aud": "https://sp.local",  
  "sub": "5be86359073c434bad2da3932222dabe",  
  "exp": 1658216714,  
  "iat": 1658216414,  
  "name": "Scott Brady",  
  "given_name": "Scott",  
  "email": "scott@scottbrady91.com",  
  "gender": "male",  
  "address": {  
    "street_address": "42 Future Way",  
    "locality": "Draper",  
    "region": "UT",  
    "postal_code": "84020",  
    "country": "US"  
  }  
}
```



3rd Party Visibility



Consider key management



Choosing the Right Encryption Algorithm



RSA Key Encryption Algorithms



RSAES-OAEP
(alg: RSA-OAEP)



RSAES-PKCS1-v1_5
(alg: RSA1_5)

RSA Key Encryption Algorithms

Algorithm	Description
RSA-OAEP	RSAs OAEP using default parameters (SHA-1 and MGF1 with SHA-1)



RSA Key Encryption Algorithms

Algorithm	Description
RSA-OAEP	RSAES OAEP using default parameters (SHA-1 and MGF1 with SHA-1)
RSA-OAEP-256	RSAES OAEP using SHA-256 and MGF1 with SHA-256
RSA-OAEP-384	RSAES OAEP using SHA-384 and MGF1 with SHA-384
RSA-OAEP-512	RSAES OAEP using SHA-512 and MGF1 with SHA-512



```
{  
  "alg": "A256GCMKW",  
  "enc": "A256GCM",  
  "typ": "JWT"  
}
```

Symmetric Encryption for Key Wrapping

Encrypt the content encryption key with symmetric encryption (rather than asymmetric encryption).

```
{
  "alg" : "ECDH-ES+A256KW",
  "enc" : "A256GCM",
  "apu" : "QWxpY2U",
  "apv" : "Qm9i",
  "epk" : {
    "kty" : "EC",
    "crv" : "P-256",
    "x" : "gI0GAILBdu7T53akrFmMyGcsF3n5d07MmwNBHKW5SV0",
    "y" : "SLW_xSffz1PWrHEVI30DHM_4egVwt3NQqeUD7nMFpps"
  }
}
```

ECDH-ES (Elliptic Curve Diffie-Hellman Ephemeral Static)

Asymmetric cryptography that makes use of an ephemeral key.

Not widely supported.

Content Encryption Algorithms



AES

(must be authenticated)



AES Content Encryption Algorithms

Algorithm	Description
A128CBC-HS256	AES-CBC using 128-bit key and HMAC-SHA-256
A192CBC-HS384	AES-CBC using 192-bit key and HMAC-SHA-384
A256CBC-HS512	AES-CBC using 256-bit key and HMAC-SHA-512

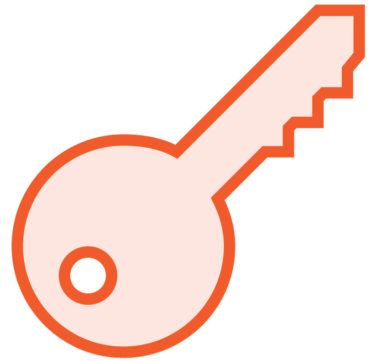


AES Content Encryption Algorithms

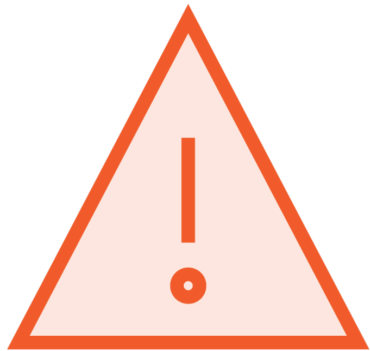
Algorithm	Description
A128CBC-HS256	AES-CBC using 128-bit key and HMAC-SHA-256
A192CBC-HS384	AES-CBC using 192-bit key and HMAC-SHA-384
A256CBC-HS512	AES-CBC using 256-bit key and HMAC-SHA-512
A128GCM	AES-GCM using 128-bit key
A192GCM	AES-GCM using 192-bit key
A256GCM	AES-GCM using 256-bit key



Content Encryption Algorithms



128-bit security is okay, 256-bit is better



Be careful not to downgrade security



There are better algorithms out there



Summary



What is symmetric and asymmetric encryption?

How to recognise and use encrypted JWTs

When to use JSON Web Encryption (JWE)

How to choose the right encryption algorithm

